

ЦЕЛЕВАЯ КОМПЛЕКСНОСТЬ ПРОГРАММЫ ПОВЫШЕНИЯ ОСВЕДОМЛЕННОСТИ СОТРУДНИКОВ ОБ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ ОРГАНИЗАЦИИ

Л.В. Астахова, С.А. Бесчастнов

Повышение осведомленности сотрудников организации об информационной безопасности занимает устойчивое место в числе объектов исследования науки и практики, что обусловлено объективными факторами. Результаты исследований показывают, что в организациях присутствуют проблемные области управления информационной безопасностью, связанные с отсутствием целенаправленно применяемой методологии обучения и профессионального развития пользователей информационных систем. Это выражается в росте числа утечек защищаемой информации, спровоцированных внутренними пользователями. Для решения этой проблемы в статье обоснована сущность принципа целевой комплексности программы повышения осведомленности сотрудников об информационной безопасности организации, его доминирующая роль в процессе проектирования структуры и содержания программы. Охарактеризовано разработанное на основе этого принципа программное средство для повышения осведомленности сотрудников, его технические параметры, функциональные возможности и отличия от других продуктов.

Ключевые слова: целевая комплексность, повышение осведомленности, программа, сотрудник, информационная безопасность.

Введение

Повышение осведомленности сотрудников организации об информационной безопасности занимает все более устойчивое место в числе объектов исследования науки и практики, что обусловлено объективными факторами. Результаты исследований показывают, что в организациях присутствуют определенные проблемные области управления информационной безопасностью, которые включают, среди прочего: отсутствие организации системы управления, неполная или устаревшая документация, отсутствие регулярного анализа рисков, отсутствие аудитов или средств контроля, ограниченное использования физических и технических средств защиты, отсутствие обучения или профессионального развития [1]. За 9 месяцев 2020 года в мире 47,4% случаев утечек спровоцированы внутренними пользователями. В России эти показатели носят еще более угрожающий характер: 79% утечек случились в результате внутренних нарушений, а доля утечек по вине сотрудников вдвое выше, чем в мире, - более

72% [2]. Эти цифры ежегодно растут, что обуславливает необходимость изучать содержание и методы повышения осведомленности, совершенствовать подходы к разработке программ с целью повышения их результативности.

Стандарты и лучшие практики для программ повышения осведомленности об информационной безопасности сосредоточены на содержании и процессах создания программ без учета того, как люди усваивают информацию и принимают решения, связанные с безопасностью [3], и без четко осознаваемых методологических подходов. Так, сравнение текущих рекомендаций по дизайну программ осведомленности об информационной безопасности, предложенных в научной литературе, с реальной практикой их разработки в трех банках Центральной и Восточной Европы позволило выявить отсутствие взаимосвязи дизайна этих программ и факторов, которые могут повлиять на соответствие пользователей требованиям политики информационной безопасности [4]. Между тем, поскольку количество нарушений безопасности в

организациях растет, понимание факторов, способствующих таким нарушениям и предотвращающих их, имеет решающее значение [5]. Императивы методологической определенности в процессе формирования программ повышения осведомленности сотрудников об информационной безопасности организации определяют актуальность изучения принципа комплексности как важнейшего компонента методологии деятельности по защите информации.

Принцип комплексности в защите информации

Принцип комплексности является аксиомой теории защиты информации. Это означает, что защита информации в организации осуществляется посредством учета комплекса всех существующих показателей информационной безопасности: целей, объектов, угроз, методов, способов, средств.

Одним из ключевых факторов, влияющих на содержание программ осведомленности, мы считаем цели защиты информации. Целевая комплексность занимает особое место в комплексной защите информации. В основе этого вида комплексности лежат реализуемые цели обеспечения конфиденциальности, целостности и доступности в их органической взаимосвязи. Поэтому мы согласны с утверждением [6] о том, что целевая комплексность доминирует и в теории, и в практике построения комплексной защиты информации. Что касается других видов комплексности (концептуальной, функциональной и структурной), то они вторичны, поскольку конкретизируют, уточняют процессы реализации целей защиты информации.

Знание целей и задач обеспечения информационной безопасности, вовлеченность в процессы их реализации также важно для сотрудника организации, как адекватный уровень ее корпоративной культуры, как сопричастность к реализации ее миссии.

Низкий уровень осведомленности сотрудников о целях и задачах защиты

информации способствует росту числа инцидентов информационной безопасности, произошедших по вине сотрудников, независимо от того, преднамеренно они действовали или непреднамеренно. Во-первых, непонимание целей и задач препятствует установлению и развитию взаимного доверия руководства и сотрудников, повышает риск деструктивного поведения последних в отношении защищаемой информации. Это выражается в умышленных дестабилизирующих воздействиях: разглашении, уничтожении, блокировании, искажении информации. Во-вторых, отсутствие знания целей и задач защиты информации сотрудниками приводит к росту инцидентов информационной безопасности, причиной которых являются непреднамеренные нарушения правил информационной безопасности (незнание, недооценка, халатность и др.).

Иными словами, для обоих типов нарушителей незнание ими целей и задач защиты информации, отсутствие вовлеченности в процессы организационной деятельности способствует снижению их лояльности к организации. Поэтому результативность проведения мероприятий по повышению осведомленности пользователей информационных систем об информационной безопасности организации напрямую зависит от понимания ими целей защиты информации.

На важность целей защиты информации в процессе работы с сотрудниками обращают внимание и зарубежные эксперты [3], утверждая, что программы повышения осведомленности о безопасности должны быть согласованы с факторами, влияющими на интернализацию целей безопасности. Эти цели должны становиться внутренними регуляторами каждого сотрудника организации.

Поэтому логично заключить, что целевая комплексность должна быть присуща и программе повышения осведомленности сотрудников об информационной безопасности. Это означает, что основой ее структуры должны быть, в первую очередь, цели защиты информации в каждой конкретной организации, которые, как

известно, определяют специфику ее средств и методов.

Четкое представление о целях защиты информации и соответствующих этим целям методах и средствах оказывает большое влияние на поведение сотрудников. Их деятельность по повышению осведомленности становится целесообразной, что, как известно, является краеугольным камнем деятельностного подхода и выражается в повышении результативности этой деятельности.

Поведенческий аспект повышения осведомленности активно изучается сегодня в науке и практике. Появился термин поведенческой осведомленности об информационной безопасности, разрабатываются соответствующие программы [7]. Однако результаты исследований по-прежнему показывают, что существующие программы образования, обучения и повышения осведомленности в области безопасности не отличаются оптимальностью, поскольку направлены на улучшение усвоения знаний сотрудниками, а не на их поведение и убеждения [8]. Изучение угроз конфиденциальности, целостности и доступности защищаемой информации способствует лучшему пониманию осведомленности пользователей об информационной безопасности и влияет на их поведение. Эксперты исследовали тесную взаимосвязь между осведомленностью об информационной безопасности и контрпродуктивным рабочим поведением и доказали, что необходимо учитывать способы улучшения знаний и отношение к повышению осведомленности, а также чувства ответственности сотрудников за информацию, с которой они работают [5].

Человек как последняя линия защиты информации, человеческий периметр – это современный тренд в отрасли информационной безопасности. Это означает, что пользователь информационной системы должен быть не только объектом деятельности специалиста по защите информации, но и ее субъектом. Так, уже существует практика наделения сотрудника организации полномочиями обнаруживать кибератаки, т.е. производить новое знание об угрозах информационной безопасности, и

оперативно оповещать о них руководство. Особенно привлекателен сотрудник как датчик социоинженерных атак. Это дает возможность не только быстро реагировать на угрозы, но и улучшать микроклимат в коллективе, повышать лояльность сотрудника к организации.

Кроме того, с точки зрения психологии рисков, зачастую человек больше боится опасности, которая затрагивает его лично, и поэтому более внимательно относится к ней и предпринимает больше усилий для её устранения. Реальная возможность контролировать угрозы основным целям защиты информации организации придает ему уверенности и способствует саморазвитию.

Считаем, что системное видение (в том числе – визуальное представление) целей защиты информации как общеориентировочной основы защиты информации организации, положенное в основу программ повышения осведомленности сотрудников, способно повысить их мотивацию к ответственному поведению с точки зрения информационной безопасности.

Программный продукт для повышения осведомленности на основе целевой комплексности

Для повышения результативности процессов повышения осведомленности сотрудников организации об информационной безопасности организации мы разработали программный продукт, в котором реализован принцип целевой комплексности. Благодаря комплексно-целевому подходу, этот продукт отличается от существующих на современном рынке.

Во-первых, большинство систем основаны не столько на принципах, сколько на примерах. С одной стороны, это позволяет сотрудникам быстро принимать решения в случае идентичной примеру ситуации. С другой стороны, работнику сложно идентифицировать себя как участника инцидента информационной безопасности, если ситуация выходит за описанные в примерах рамки. Наше решение основано на методологии комплексности и нацелено на

то, чтобы сотрудник, кроме узконаправленных навыков, приобретал понимание, когда ситуация становится инцидентом информационной безопасности, и своевременно мог довести эту информацию до уполномоченных лиц, ответственных за информационную безопасность организации.

Во-вторых, системы, представленные на рынке, ограничены тем, что их материалы становятся неактуальными после прохождения мероприятий. Мы предлагаем систему, которая поддерживается не сторонними компаниями, а компетентными работниками профильных служб, хорошо знающими специфику защиты информации в организации.

В-третьих, средства, предоставляемые крупными компаниями-производителями, в лучшем случае требуют браузера и, соответственно - выхода в интернет. Для компаний, не подключенных к глобальной сети, прохождение таких тренингов сотрудниками проблематично. Наше решение может располагаться не только в локальной сети организации, но и на компьютерах каждого сотрудника, не требуя установки или дополнительного программного обеспечения.

В-четвертых, рыночные продукты стараются сделать запоминающимися и привлекающими внимание, что, с одной стороны, не лишено смысла. Однако, с другой

стороны, это не позволяет сотруднику использовать их как приложение для заднего фона. Это учтено в нашей программе.

Цель нашей программы - представление максимально простого интерфейса доведения информации об информационной безопасности для пользователя и для разработчиков новых курсов об информационной безопасности (рис. 1). В основу содержания курсов положены ключевые цели информационной безопасности: конфиденциальность; целостность; доступность.

Программа написана на Windows Form C# платформы .NET Framework 4.7.2, что позволяет запустить её на самых популярных системах Windows, на системах Unix и при дальнейшем развитии - на смартфонах. Интерфейс программы выполнен в минималистической цветовой гамме с минимумом ярких элементов использования решения как настольного (фоновое).

Процесс работы с программой выглядит следующим образом. Сотрудник с определенной периодичностью осваивает курсы программы и проходит тесты, представленные в программе.

Состав курсов основан на доведении до сотрудников базовых целей информационной безопасности: конфиденциальность, целостность, доступность (рис. 2).

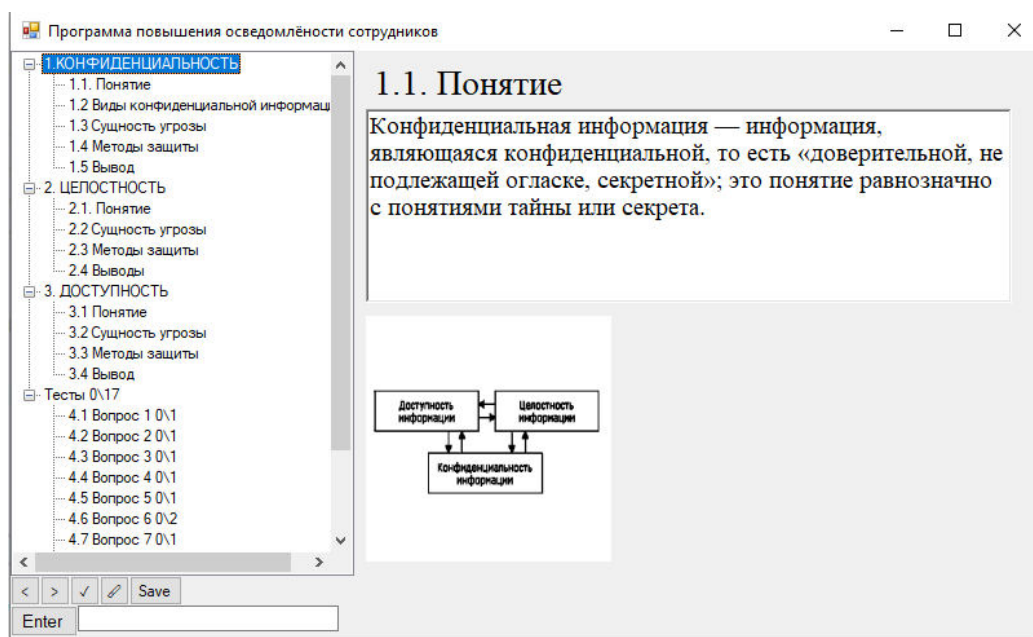


Рис. 1. Интерфейс программы

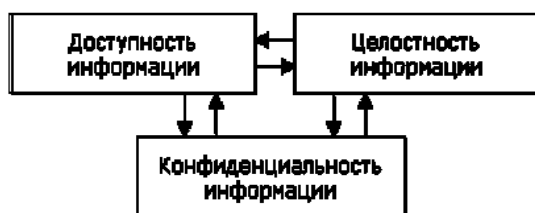


Рис. 2. Цели защиты информации, лежащие в основе программы повышения осведомленности

Сотрудник обновляет свои знания в сфере информационной безопасности, может оценить их уровень, а также в любое время обратиться к оставленному на заднем фоне приложению для получения инструкций о своих действиях, если опознал какую-либо ситуацию как инцидент информационной безопасности.

Функционал программы включает: отображение всех загруженных курсов, оценок за все тесты и максимальный рейтинг по курсу; доведение текстовых материалов (рис. 3).

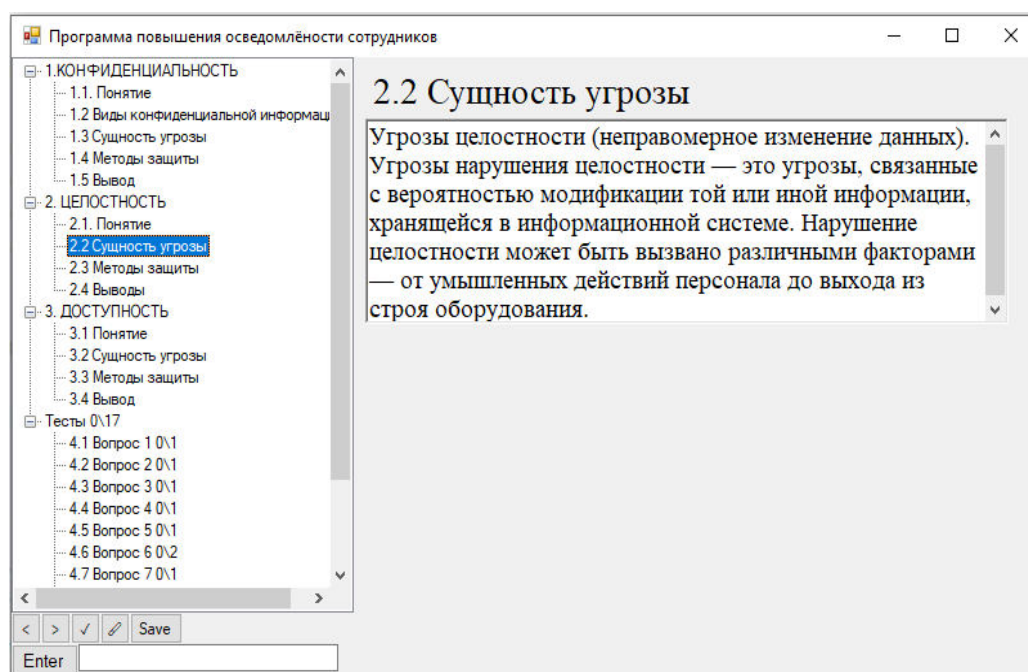


Рис. 3. Панель текстовых материалов

К функциям программного продукта относятся также показ изображений; проведение тестовых заданий, их оценка и отображение оценки; сохранение результатов прохождения тестов (название курса, полная запись времени и даты сохранения

результатов, общий рейтинг уровня осведомленности и рейтинг по каждому тесту в отдельности) (рис. 4). Приложение позволяет свободно масштабировать все элементы и увеличивать размеры кегля теста.

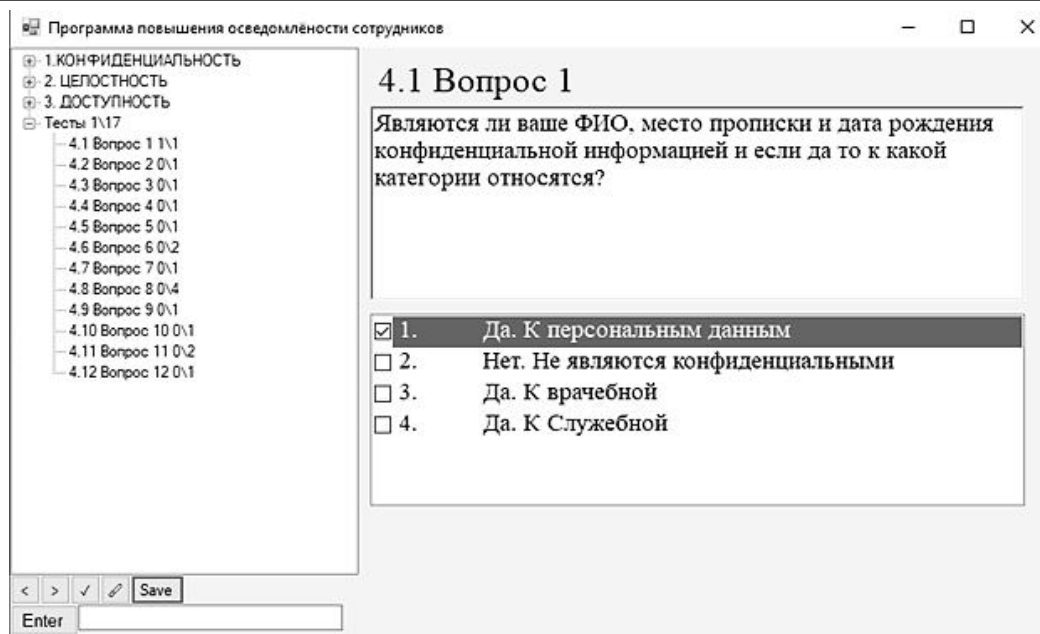


Рис. 4. Панель тестирования

Работа с программой является частью общей системы повышения осведомлённости в организации. При добавлении нового курса по информационной безопасности или появлении нового сотрудника, а также при внедрении решения в уже существующую систему, мы определяем следующий порядок.

Курсы, разработанные специалистами по защите информации, в соответствии с текущей ситуацией организации, размещаются в корне решения.

Решение может располагаться на сетевом диске, тем самым исключая необходимость загрузки курсов и последующего сбора результатов теста с каждого ЭВМ индивидуально или на персональных компьютерах.

Результатом нажатия кнопки «Save» является снимок экрана программы. После этого итоги прохождения курсов могут автоматически собираться, для чего предусмотрен предельно упрощенный синтаксис сохраняемых результатов (рис. 5).

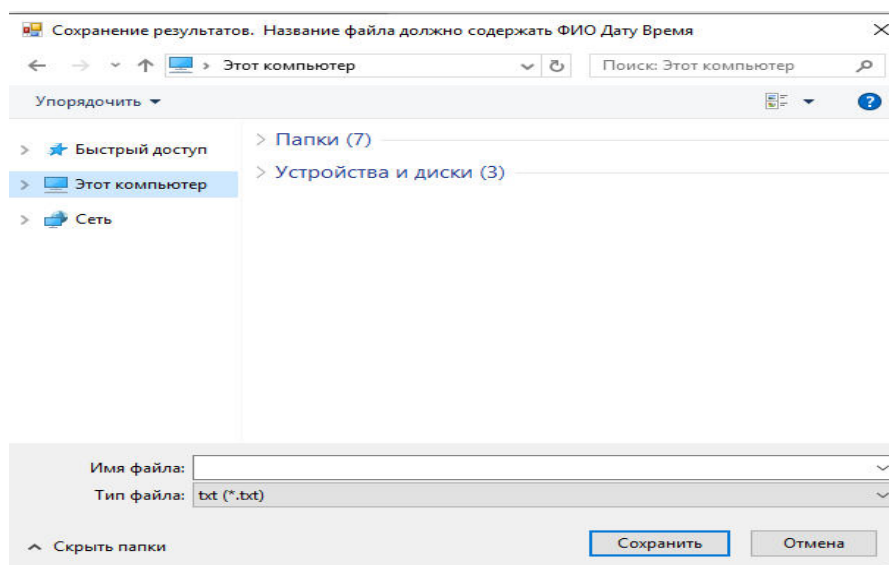


Рис. 5. Окно сохранения результатов

Результаты тестирования сотрудников также могут быть непосредственно просмотрены руководителем (рис. 6). Таким образом программа дает представление об осведомленности сотрудников в сфере информационной безопасности.

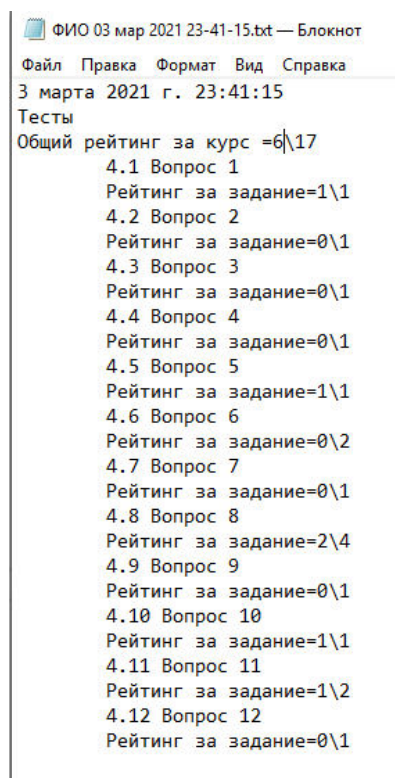


Рис. 6. Пример сохранённых результатов тестирования

Данное решение разработано для небольших организаций. Актуальность материалов могут поддерживать компетентные сотрудники на местах (системные администраторы, отдел защиты информации). Продукт является хорошей базой для дальнейшего развития системы управления осведомлённостью сотрудников в сфере информационной безопасности для организаций любого уровня.

В настоящее время проводится работа по расширению его функционала: воспроизведение видео; полноэкранный режим; сворачивание в область уведомлений; расширение числа курсов и их специализация для разных категорий сотрудников, внутренний обмен циркулярными сообщениями и использование как внутреннего мессенджера организации и др.

Таким образом, применение принципа целевой комплексности для управления

осведомленностью сотрудников об информационной безопасности организации способствует повышению его результативности и потому требует изменения контента программ повышения осведомленности и новых технических решений. Разработанное программное решение отвечает этим требованиям. Оно является простой и экономичной платформой для визуализации структурных частей системы целей защиты информации и методов их реализации; достижения целесообразности деятельности по обучению сотрудников правилам информационной безопасности; контроля их усвоения; адаптации к угрозам и рискам информационной безопасности конкретной организации и др. Перспективным направлением развития продукта является его использование как внутреннего мессенджера организации для обмена сотрудниками информацией о проблемах осведомленности об информационной безопасности.

Список литературы

1. Szczepaniuk E.K., Szczepaniuk H., Rokicki T., Klepacki B. Information security assessment in public administration // Computers & Security. - 2020. - Vol. 90, 101709. URL: <https://www.sciencedirect.com/science/article/pii/S0167404819302469> (дата обращения: 20.02.2021).
2. InfoWatch. Утечки информации ограниченного доступа: отчет за 9 месяцев 2020. URL: <https://www.infowatch.ru/analytics/reports/30708> (дата обращения: 14.02.2021).
3. Tsohou A., Karyda M., Kokolakis S., Analyzing the role of cognitive and cultural biases in the internalization of information security policies: Recommendations for information security awareness programs // Computers & Security. 2015. Vol. 52. P. 128-141. URL: <https://www.sciencedirect.com/science/article/pii/S0167404815000565> (дата обращения: 20.02.2021).
4. Bauer S., Bernroider E.W.N., Chudzikowski K. Prevention is better than cure! Designing information security awareness programs to overcome users' non-compliance with information security policies in banks // Computers & Security. 2017. Vol. 68. P. 145-

159. URL: <https://www.sciencedirect.com/science/article/pii/S0167404817300871> (дата обращения: 17.02.2021).
5. Hadlington L., Binder J., Stanulewicz N. Exploring role of moral disengagement and counterproductive work behaviours in information security awareness // *Computers in Human Behavior*. 2021. Vol. 114, 106557. URL: <https://www.sciencedirect.com/science/article/pii/S0747563220303071> (дата обращения: 19.02.2021).
6. Мещерякова Т.В., Фирюлин М.Е. Принципы обеспечения комплексной защиты информации центров обработки данных // *Вестник Воронежского института МВД России*. 2015. № 2. С. 245-249.
7. Trim P. R.J., Lee Y.-Im. The role of B2B marketers in increasing cyber security awareness and influencing behavioural change // *Industrial Marketing Management*. – 2019. – Vol. 83. – P. 224-238. URL: <https://www.sciencedirect.com/science/article/pii/S0019850118301561> (дата обращения: 13.02.2021).
8. Alshaikh M., Maynard S. B., Ahmad A. Applying social marketing to evaluate current security education training and awareness programs in organisations // *Computers & Security*. – 2021. - Vol. 100, 102090. URL: <https://www.sciencedirect.com/science/article/pii/S0167404820303631> (дата обращения: 16.02.2021).

Южно-Уральский государственный университет
(национальный исследовательский университет)
South Ural State University (National Research University)

Поступила в редакцию 11.03.2021

Информация об авторах

Астахова Людмила Викторовна – д-р пед. наук, профессор, профессор кафедры защиты информации, Южно-Уральский государственный университет (национальный исследовательский университет), e-mail: astakhovalv@susu.ru

Бесчастнов Семён Александрович – студент кафедры защиты информации, Южно-Уральский государственный университет (национальный исследовательский университет), e-mail: zelod777@mail.ru

TARGETED COMPREHENSION OF THE PROGRAM OF INCREASING AWARENESS OF EMPLOYEES ON INFORMATION SECURITY OF THE ORGANIZATION

L.V. Astakhova, S.A. Beschastnov

Raising the awareness of employees of the organization about information security takes a stable place among the objects of research in science and practice, which is due to objective factors. Research results show that organizations have problem areas of information security management associated with the lack of a purposefully applied methodology for training and professional development of information system users. This leads to an increasing number of information leaks through the fault of users. To solve this problem, the article substantiates the essence of the principle of the target complexity of the program for raising the awareness of employees about the information security of an organization, its dominant role in the process of designing the structure and content of the program. A software tool developed based on this principle for raising employee awareness, its technical parameters, functionality, and differences from other products is characterized.

Keywords: target complexity, awareness raising, program, employee, information security.

Submitted 11.03.2021

Information about the authors

Lyudmila V. Astakhova - Dr. Sc. (Pedagogy), Professor, Professor of the Department of Information Security, South Ural State University (National Research University), e-mail: astakhovalv@susu.ru

Semyon A. Beschastnov - student of the Department of Information Security, South Ural State University (National Research University), e-mail: zelod777@mail.ru